Trabajo Final

Alumno: Miguel A. Acosta DNI 77478992L
Curso: Ciberseguridad
Instructor: Sergio D. Ballen
Ciudad: Madrid
Fecha: 23 de marzo 2026

INFORME TÉCNICO FORENSE

SANS DFIR

Análisis forense de servidor Debian potencialmente comprometido

Resumen ejecutivo

Se realizó un análisis forense sobre la evidencia ImagenServidorFinal.E01, correspondiente a un servidor Debian GNU/Linux 12.7 con hostname debian, procesado mediante Autopsy.

El objetivo fue determinar el estado de seguridad del host, identificar indicios de compromiso, reconstruir la secuencia temporal de eventos, documentar configuraciones inseguras y definir acciones de contención, erradicación y recuperación.

La evidencia permitió diferenciar dos ventanas de tiempo principales:

i) La primera, el 30/09/2024, corresponde al despliegue del stack web, con instalación de Apache2, MariaDB, PHP y WordPress, junto con actividad local de administración del sitio desde el navegador del propio sistema.
ii) La segunda, el 08/10/2024, concentra cambios de mayor criticidad: instalación de vsftpd, modificación de sshd_config, alteraciones de /etc/passwd y /etc/shadow, y actividad adicional en logs del sistema.

El análisis de configuraciones confirmó debilidades severas: SSH permitía login de root por contraseña, FTP admitía acceso anónimo con escritura y sin cifrado, y WordPress utilizaba credenciales débiles y salts por defecto.

Adicionalmente, se recuperó el artefacto /root/.mysql_history, cuyo contenido evidenció la creación de la cuenta user@localhost y la concesión de privilegios globales administrativos mediante ALL PRIVILEGES ON *.* WITH GRANT OPTION. Esta cuenta debe tratarse como no autorizada y de alto riesgo, al permitir control total del motor MariaDB y facilitar persistencia o abuso posterior.

Por otro lado, el access.log revisado mostró únicamente tráfico desde 127.0.0.1 y ::1, compatible con instalación y administración local de WordPress, sin evidencia directa en ese registro de explotación remota vía Apache.

También registro acceso remoto exitoso al servidor. En concreto, el log mostró el evento Accepted password for root from 192.168.0.134, seguido de la apertura de sesión para el usuario root, lo que demuestra que el acceso no autorizado se produjo mediante autenticación por contraseña sobre el servicio SSH

Tampoco se identificó una web shell inequívoca ni persistencia clásica concluyente con el material revisado.

La conclusión técnica es que el servidor presentaba una exposición crítica, una superficie de ataque injustificadamente amplia y cambios sensibles en autenticación y servicios remotos.

Por ello, la respuesta adecuada consiste en contención, validación de cuentas, reconstrucción controlada y hardening integral.

Identificación del caso

- Evidencia principal: ImagenServidorFinal.E01
- Tipo de evidencia: imagen forense segmentada E01
- Sistema analizado: Debian GNU/Linux 12.7
- Hostname: debian
- Zona horaria del sistema: US/Eastern
- Zona horaria observada en Autopsy: Europe/Madrid / CEST
- Examinador: Miguel Angel Acosta
- Herramienta principal: Autopsy
- Caso de trabajo: 20260503_trabajo_final
- HASH de la imagen: MD5 96e7972c41e2a1fcf8a8f408cbfe92e3

Adquisición de la imagen forense

La evidencia analizada no procedía de un disco físico conectado directamente al equipo forense, sino de un servidor Debian 12 virtualizado. El sistema objetivo se encontraba desplegado como máquina virtual, por lo que el soporte original a preservar era el archivo de disco virtual.

Con el fin de obtener una copia apta para análisis forense, se realizó una conversión del disco virtual a un formato plano de análisis mediante la herramienta Exterro FTK IMAGER y qemu-img. Este procedimiento permitió transformar el archivo de disco virtual original a una imagen RAW, conservando la estructura lógica del sistema de archivos y los artefactos del sistema operativo necesarios para la investigación.

A partir de esa imagen, se generó la evidencia de trabajo en formato E01 segmentado, identificada en el caso como ImagenServidorFinal.E01, que fue

posteriormente cargada y procesada en Autopsy. Este enfoque permitió trabajar sobre una copia forense del sistema, evitando interactuar directamente con la máquina comprometida y manteniendo separadas las fases de adquisición y análisis.

La imagen fue examinada desde una estación de trabajo con Windows 11, utilizando Autopsy como herramienta principal. Durante el procesamiento se activaron módulos de ingest orientados a cronología, actividad reciente, búsqueda por palabras clave, identificación de archivos interesantes, carving y análisis adicional de artefactos.

LINEA TEMPORAL

La correlación temporal de los artefactos analizados permite reconstruir una secuencia de eventos altamente significativa desde el punto de vista forense:

Fecha y hora	**Evento observado**	**Interpretación técnica**
2024-09-30 16:44:28 CEST	Activación de apache2.service	Inicio del despliegue del servicio web
2024-09-30 17:06:07 CEST	Activación de mariadb.service	Inicialización de la base de datos
2024-09-30 17:06:06 CEST	Modificación de /etc/mysql/debian.cnf	Configuración local de acceso a MariaDB
2024-09-30 18:02:41 CEST	Modificación de /var/www/html/wp-config.php	Configuración de WordPress y credenciales de BD
2024-09-30 18:23:12 CEST	Creación de /var/www/html/.htaccess	Ajuste manual de reglas del sitio
2024-09-30 18:23:11 CEST	Creación de tablas WordPress en /var/lib/mysql/wordpress/	Puesta en marcha lógica de la aplicación
2024-09-30 18:25:15 CEST	Activación de ssh.service	Habilitación de acceso remoto administrativo
2024-09-30 21:35:38 CEST	Modificación de .bash_history del usuario debian	Evidencia de actividad interactiva por consola
2024-09-30 21:36:44 CEST	Creación de /root/.mysql_history	Ejecución de comandos MySQL con privilegios elevados
2024-10-08 17:40:59 CEST	acceso SSH exitoso como root desde 192.168.0.134	Acceso no autorizado desde remoto
2024-10-08 22:09:00 CEST	Modificación de /etc/passwd y /etc/shadow	Cambio de cuentas, contraseñas o identidades locales
2024-10-08 22:09:00 CEST	Activación de vsftpd.service	Exposición o habilitación de un nuevo vector remoto

Fecha y hora	Evento observado	Interpretación técnica
2024-10-08 22:10:11 CEST	Modificación de /etc/vsftpd.conf	Configuración específica del servicio FTP
2024-10-08 22:14:02 CEST	Modificación de /etc/ssh/sshd_config	Reconfiguración del acceso SSH
2024-10-08 22:24:04 CEST	Modificación de /etc/apache2/apache2.conf	Cambio posterior sobre la configuración del servidor web
2024-10-08 22:58:48 CEST	Actualización de access.log	Persistencia de tráfico HTTP hasta el final de la ventana analizada
2024-10-08 23:28:38 CEST	Actualización de error.log	Registro de errores/eventos operativos posteriores
2024-10-09 00:03:08 CEST	Actualización de system.journal	Actividad de sistema posterior al evento principal

PREPARACIÓN

La fase de preparación, dentro del contexto del análisis forense, se centra en la organización del caso, validación del entorno de trabajo y comprobación de la capacidad de la herramienta para procesar la evidencia.

Preparación del caso forense

Se trabajó sobre la evidencia ImagenServidorFinal.E01, cargada en Autopsy dentro del caso 20260503_trabajo_final.

Se realizo el análisis con los módulos de ingest, incluyendo:

- Recent Activity
- Keyword Search
- Hash Lookup
- Interesting Files Identifier
- Encryption Detection
- Embedded File Extractor
- Plaso
- YARA Analyzer
- PhotoRec Carver

Validación técnica del procesamiento

Se observaron incidencias de procesamiento no críticas:

- Advertencia sobre partición **Linux Swap**, no montada como sistema de archivos navegable.
- Avisos de Apache Tika al extraer metadatos o texto de algunos archivos;
- Error de exportación a Excel por superar el límite máximo de filas por hoja.

Estas incidencias afectan al procesamiento documental, pero no comprometen la validez general del análisis.

Preparación para correlación temporal

Se detectó una diferencia coherente entre la zona horaria del host (US/Eastern) y la visualización de Autopsy (CEST). La correlación con dpkg.log confirmó una diferencia aproximada de seis horas, considerada durante toda la reconstrucción cronológica.

IDENTIFICACIÓN

En esta fase se identifican los eventos relevantes, artefactos críticos, configuraciones de riesgo e indicadores asociados al posible incidente.

Identificación de la primera ventana: despliegue del entorno

La revisión de dpkg.log, timeline y artefactos web confirmó que el 30/09/2024 se instaló el stack principal del servidor:

- Apache2
- MariaDB
- PHP y módulos asociados
- WordPress

Los artefactos de Web History mostraron acceso local a:

- http://localhost/
- http://localhost/wp-admin/install.php
- http://localhost/wp-login.php
- http://localhost/wp-admin/

Además, Web Account Type asoció un rol administrativo a WordPress durante el flujo de instalación.

No se Identificó ningún archivo comprometido en la imagen del sistema. Tampoco se observó rootkit o archivos malware en el sistema.

Si se evidencio una descarga, el concreto el archivo " xampp-osx-8.0.28-0-installer.dmg" y visitas a páginas web como www.git-scm.com, pero no se puede asegurar la instalación o ejecución de estos, porque no existen logs o registros.

Esta evidencia es compatible con una fase de despliegue y administración local del entorno web desde el propio host.

Identificación de la segunda ventana: cambios críticos del 08/10/2024

Durante el 08/10/2024 se observaron eventos de mayor sensibilidad:

- Instalación de vsftpd
- Instalación de net-tools
- Modificación de sshd_config

- Modificación de /etc/passwd
- Modificación de /etc/shadow
- Modificación de vsftpd.conf
- Actividad continuada en logs y journal

Esta segunda ventana constituye el núcleo de mayor riesgo del caso, al afectar servicios remotos y el plano de autenticación del sistema.

Identificación de configuraciones inseguras

SSH

El archivo sshd_config mostró:

- PermitRootLogin yes
- PasswordAuthentication yes

El sistema permitía login remoto del usuario root mediante contraseña.

FTP

El archivo vsftpd.conf mostró:

- anonymous_enable=YES
- local_enable=YES
- write_enable=YES
- ssl_enable=NO

El servidor FTP estaba configurado con acceso anónimo, escritura habilitada y sin cifrado.

WordPress

El archivo wp-config.php mostró:

- DB_USER = wordpressuser
- DB_PASSWORD = 123456

- salts por defecto: put your unique phrase here

WordPress se desplegó con credenciales débiles y secretos no personalizados.

Identificación de actividad web observada

El access.log revisado mostró únicamente accesos desde:

- 127.0.0.1::1

Las peticiones observadas son coherentes con:

- Instalación de WordPress
- Autenticación local
- Administración del dashboard
- Peticiones AJAX normales

Con el log disponible no hay evidencia directa de acceso remoto externo al servicio web.

Identificación de actividad de autenticación

El análisis de wtmp mostró sesiones locales del usuario debian en tty7. Btmp reflejó registros compatibles con intentos fallidos de autenticación local en entorno gráfico, asociados a identificadores como deb y kali.

Existe actividad de autenticación local y eventos fallido.

Identificación de ausencia de implante inequívoco

No se localizó de forma concluyente:

- Web shell nominativa
- Authorized_keys malicioso
- Cron malicioso
- Servicio de persistencia personalizado
- Backdoor inequívoco

El archivo .htaccess analizado no mostró manipulación maliciosa aparente.

No se identificó persistencia clásica concluyente con el material revisado.

Identificación de cuenta no autorizada en MariaDB

El análisis del artefacto /root/.mysql_history permitió recuperar sentencias SQL de creación y concesión de privilegios sobre cuentas de base de datos. Entre ellas destacó CREATE USER 'user'@'localhost' IDENTIFIED BY 'password';, seguida de GRANT ALL PRIVILEGES ON *.* TO 'user'@'localhost' WITH GRANT OPTION;.

La posterior verificación con SHOW GRANTS confirmó privilegios globales administrativos. Este hallazgo debe tratarse como una cuenta no autorizada de alto riesgo, compatible con abuso de privilegios o mecanismo de persistencia a nivel de MariaDB.

Debido a la falta de logs, no se puede obtener información sobre cuando, se creo, desde que ip o sesión se realizo y cuales acciones realizo este usuario.

Aunque el artefacto .mysql_history no permite fijar por sí solo el segundo exacto de creación, la correlación temporal lo sitúa dentro de la ventana del 30/09/2024 asociada a actividad interactiva con privilegios elevados.

CONTENCIÓN

A partir de los hallazgos identificados, la fase de contención debe orientarse a reducir inmediatamente la exposición del host y evitar la continuidad de un posible acceso no autorizado.

Aislamiento del host

Se recomienda:

- Aislar lógicamente el servidor de redes de producción o laboratorio compartido;
- Permitir acceso solo al equipo de análisis;
- Preservar el estado del sistema antes de cambios mayores si se requieren más adquisiciones.

Contención de servicios remotos inseguros

Deben deshabilitarse o restringirse de inmediato:

- Vsftpd
- Acceso SSH con root por contraseña

Medidas mínimas recomendadas:

```
$ sudo systemctl stop vsftpd
$ sudo systemctl disable vsftpd
$ sudo ufw deny 21/tcp
```

Contención del acceso administrativo

Cambios inmediatos sobre SSH:

- PermitRootLogin no
- PasswordAuthentication no

Y acceso solo mediante:

- Clave pública

- IPs de administración autorizadas
- Segmentación de red o VPN

Contención del entorno WordPress

Se recomienda:

- Bloquear credenciales débiles;
- Revisar y corregir permisos del webroot;
- Restringir administración del CMS a personal autorizado;
- Validar integridad del contenido antes de mantener el servicio expuesto.

ERRADICACION

La erradicación se orienta a eliminar condiciones inseguras, accesos indebidos, credenciales débiles y exposición innecesaria.

Erradicación de la exposición FTP

La medida preferente es la eliminación del servicio si no existe una necesidad operativa real. Si se requiere transferencia de archivos, debe sustituirse por SFTP.

Erradicación de configuraciones inseguras de SSH

Debe eliminarse la capacidad de:

- login remoto de root;

Erradicación de debilidades en WordPress

Debe actuarse sobre:

- contraseña de base de datos
- usuario de aplicación si procede
- regeneración de salts y claves
- revisión de plugins, temas y núcleo del CMS
- control de permisos de archivos

Validación de cuentas locales

Dado que /etc/passwd y /etc/shadow fueron modificados en la ventana crítica, deben revisarse:

- Cuentas existentes
- Shells válidos
- Grupos privilegiados

- Contraseñas administrativas
- Posibles cuentas no autorizadas

Búsqueda de persistencia residual

Aunque no se halló persistencia clásica concluyente, deben revisarse formalmente:

- Cron y systemd timers
- Claves SSH
- Directorios temporales
- Servicios habilitados al arranque
- Cambios recientes en /etc, /root, /home/debian, /var/www/html

Eliminación de “user” con privilegios sospechoso

Debe eliminarse el usuario con privilegios “user” el cual tiene acceso total la base de datos.

RECUPERACIÓN

La recuperación debe realizarse bajo criterios de confianza mínima y reconstrucción controlada.

Estrategia de recuperación recomendada

La opción más segura es:

1. preservar evidencia final;
2. Reinstalar Debian desde fuente confiable;
3. Actualizar completamente el sistema;
4. Desplegar solo servicios necesarios;
5. Restaurar el sitio y la base de datos de forma controlada;
6. Aplicar hardening integral;
7. Validar funcionalidad y seguridad antes de reexponer el servicio.
8. Instalar y habilitar rsyslog para disponer de trazabilidad persistente en texto plano, incluyendo el registro de autenticación en /var/log/auth.log.

Restauración del servicio web

La restauración de WordPress no debe basarse en copia ciega del directorio comprometido. Debe incluir:

- Núcleo WordPress desde fuente legítima;
- Revisión de wp-content;
- Importación controlada de base de datos;
- Nueva configuración de wp-config.php;

- Regeneración de claves y secretos.

Validación post-recuperación

La recuperación no debe considerarse completada hasta verificar:

- Inexistencia de cuentas no autorizadas.
- Eliminación de FTP inseguro o su sustitución.
- Endurecimiento de SSH.
- Credenciales rotadas.
- Permisos corregidos.
- Revisión de logs y monitorización básica activa.
- Verificar la existencia y escritura correcta de /var/log/auth.log tras la instalación de rsyslog.
- Confirmar que los eventos de sudo y SSH quedan registrados de forma persistente y auditable.

LECCIONES APRENDIDAS

Esta fase recoge las conclusiones estratégicas y las mejoras estructurales necesarias para evitar recurrencia.

Lección 1: el problema principal fue la mala configuración

La evidencia no demuestra de forma concluyente una explotación remota exitosa vía Apache con el log disponible, pero sí demuestra una **postura de seguridad deficiente**:

- Root por SSH con contraseña.
- FTP anónimo con escritura y sin cifrado.
- WordPress con credenciales triviales y salts por defecto.

El sistema era vulnerable por diseño operativo.

Lección 2: la superficie de ataque creció después del despliegue inicial

Vsftpd fue instalado después de la puesta en marcha del stack web. Esto indica una ampliación posterior de la exposición del host, sin justificación suficiente y en una ventana temporal sensible.

Lección 3: el logging disponible fue insuficiente para atribución plena

La ausencia de un auth.log completo o de un journal íntegro de autenticación limita la atribución del vector exacto. Esto evidencia necesidad de una política de logging más robusta y fácilmente auditable.

Lección aprendida 4: la recuperación no debe limitarse a “arreglar” el síntoma

Cuando existen cambios en autenticación y servicios remotos dentro de una ventana crítica, la respuesta correcta no es solo editar configuraciones, sino reconstruir el host desde una base confiable.

Lección aprendida 5: archivos “inexistentes” de registros

No se obtuvo evidencia concluyente de borrado selectivo de auth.log; sin embargo, la ausencia de trazabilidad completa y la dependencia inicial de journald dificultaron la atribución exacta de algunas acciones. Esta limitación justificó la incorporación de una política de logging más robusta mediante rsyslog.

Lección 6: el hardening debe formar parte del despliegue, no aplicarse después

El despliegue inicial del sistema fue funcional, pero no seguro. El hardening debe integrarse desde el diseño:

- Mínimo privilegio
- Cierre de puertos
- Autenticación fuerte
- Secretos robustos
- Revisión de configuración antes de exponer servicios

Indicadores clave del caso

Indicadores de configuración insegura

- PermitRootLogin yes
- PasswordAuthentication yes
- anonymous_enable=YES
- write_enable=YES
- ssl_enable=NO
- DB_PASSWORD = 123456
- salts por defecto de WordPress

Indicadores de cambio crítico

- Instalación de vsftpd el 08/10/2024
- Modificación de sshd_config
- Modificación de /etc/passwd
- Modificación de /etc/shadow
- Actividad en btmp/wtmp
- Continuidad de actividad en Apache y journal

CONCLUSIÓN

Bajo una estructura SANS DFIR, la evidencia permite concluir que el servidor Debian analizado atravesó una fase de despliegue local legítimo seguida por una fase posterior de cambios críticos sobre servicios remotos y autenticación.

Aunque el access.log revisado no demuestra intrusión remota vía Apache, el sistema presentaba una configuración críticamente insegura en SSH, FTP y WordPress.

En concreto muestra una intrusión al sistema desde un ip 192.168.0.134 a travez del servicio SSH. Esto despuesta su tratamiento como activo potencialmente comprometido.

No se identificó una web shell ni persistencia clásica concluyente con el material revisado, pero la combinación de cambios sobre credenciales, instalación tardía de FTP y exposición remota deficiente impide mantener confianza operativa en el host.

Tampoco se localizó archivos rootkit o malware dentro de los archivos en la muestra.

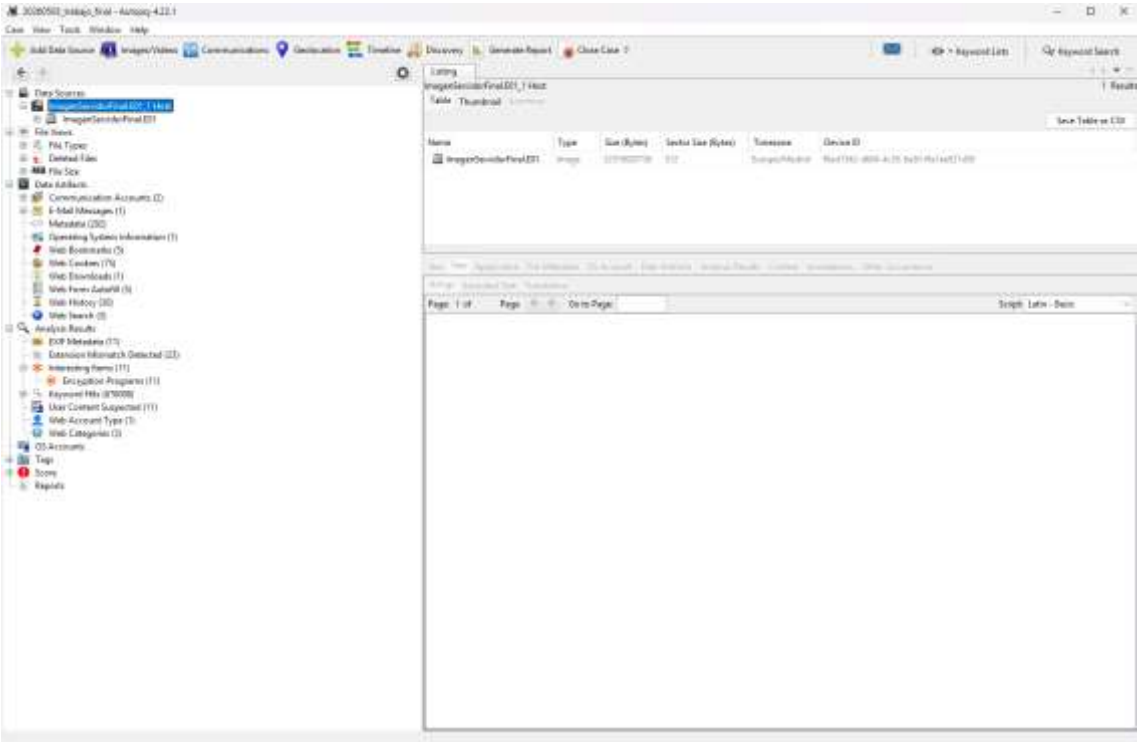
La visita a web sospechosas se detecto como evidencia de actividad maliciosa.

La existencia de un usuario con privilegios excesivos aparentemente creado por el usuario malicioso denota un compromiso de la seguridad de la base de datos y una posible fuga de datos de la misma.

La respuesta adecuada consiste en contención inmediata, validación de cuentas, erradicación de configuraciones inseguras, recuperación sobre una base confiable y adopción de controles permanentes de hardening y monitorización.

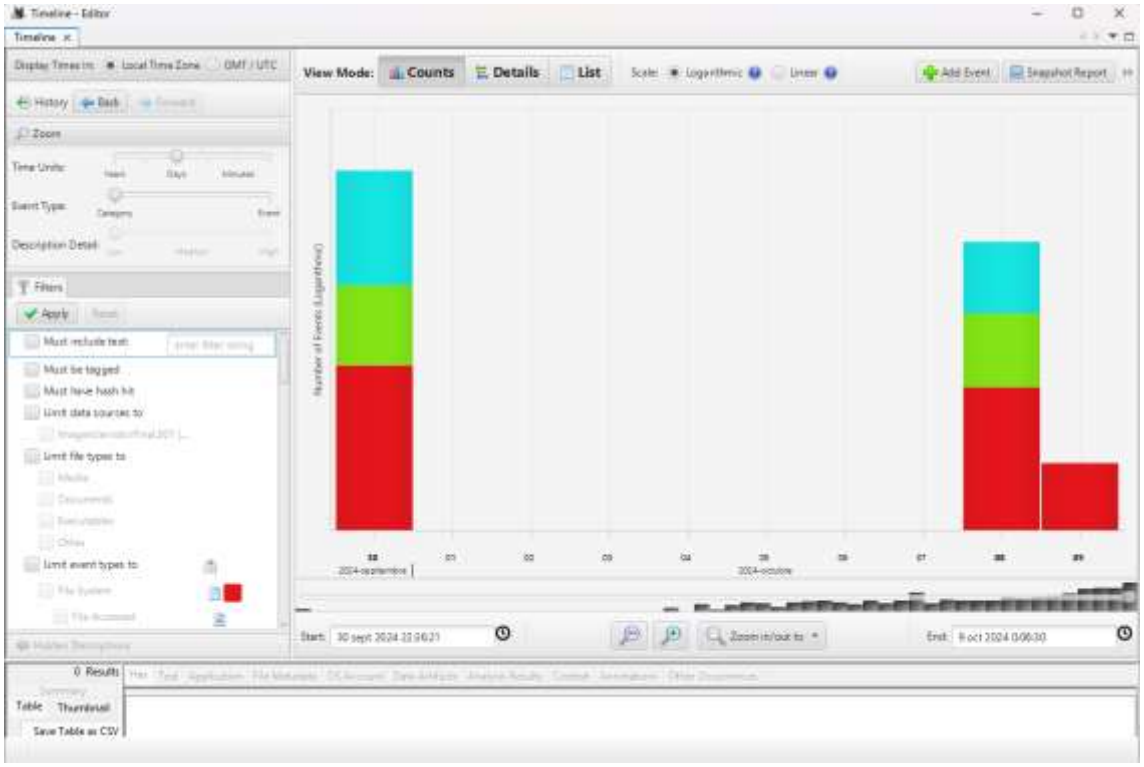
ANEXOS

Vista general

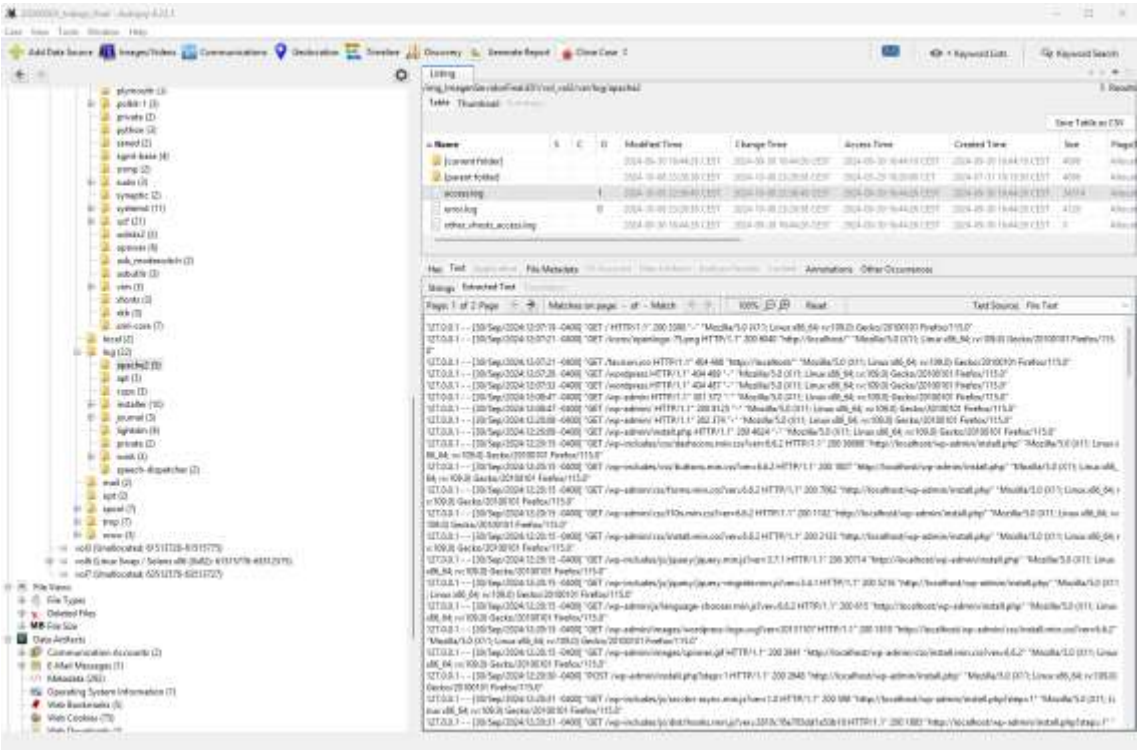


```
Oct 08 17:28:37 debian systemd[1]: Starting ssh.service - OpenBSD Secure Shell server...
Oct 08 17:28:38 debian sshd[550]: Server listening on 0.0.0.0 port 22.
Oct 08 17:28:38 debian sshd[550]: Server listening on :: port 22.
Oct 08 17:28:38 debian systemd[1]: Started ssh.service - OpenBSD Secure Shell server.
Oct 08 17:40:59 debian sshd[1650]: Accepted password for root from 192.168.0.134 port 45623 ssh2
Oct 08 17:40:59 debian sshd[1650]: pam_unix(sshd:session): session opened for user root(uid=0) by (uid=0)
Oct 08 17:40:59 debian sshd[1650]: pam_env(sshd:session): deprecated reading of user environment enabled
```

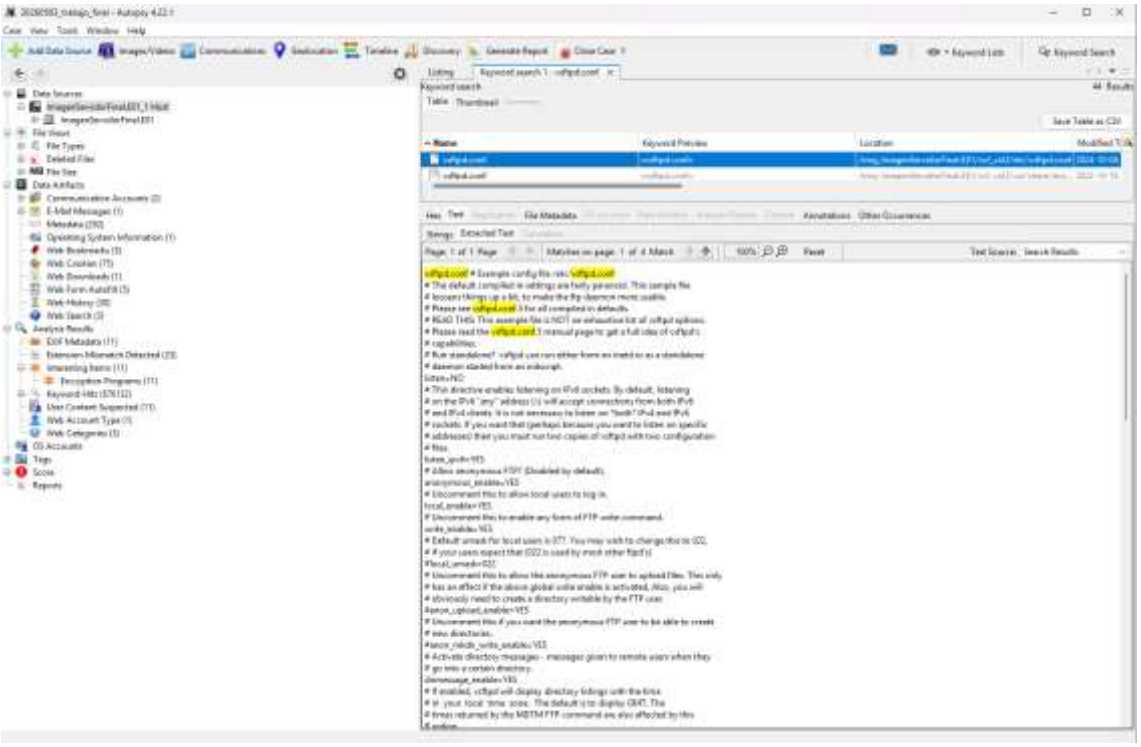
Línea Temporal de Eventos Relevantes



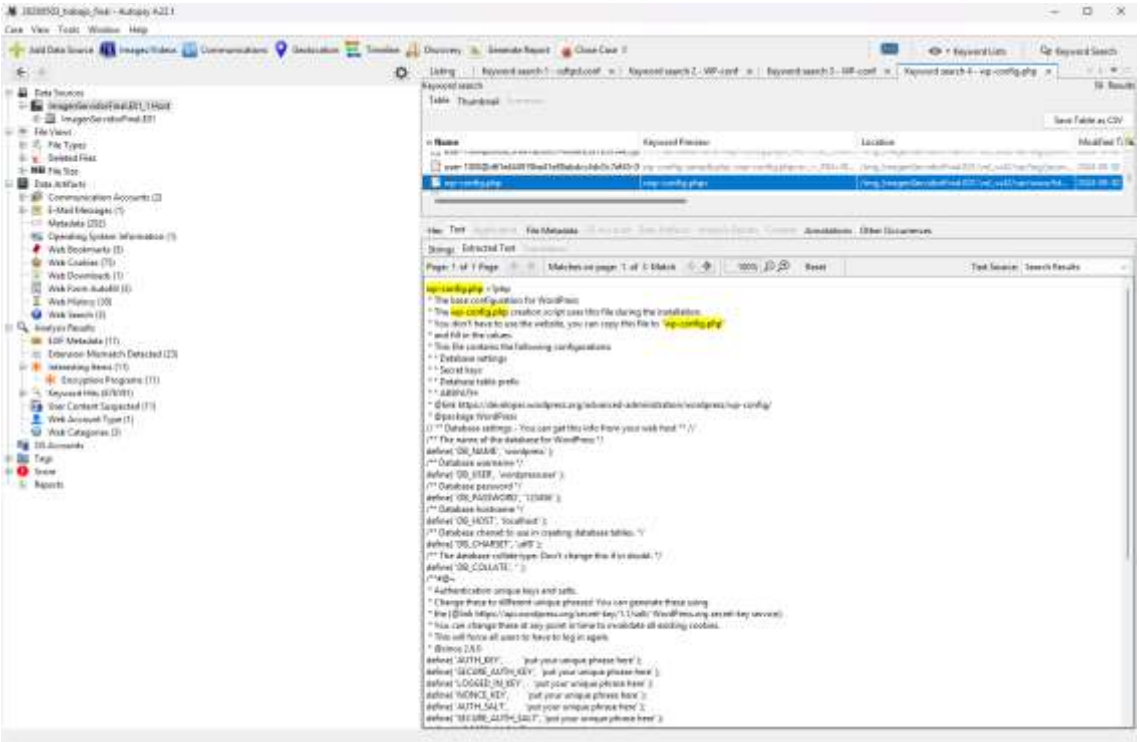
Visualización del Archivo ACCESS.LOG



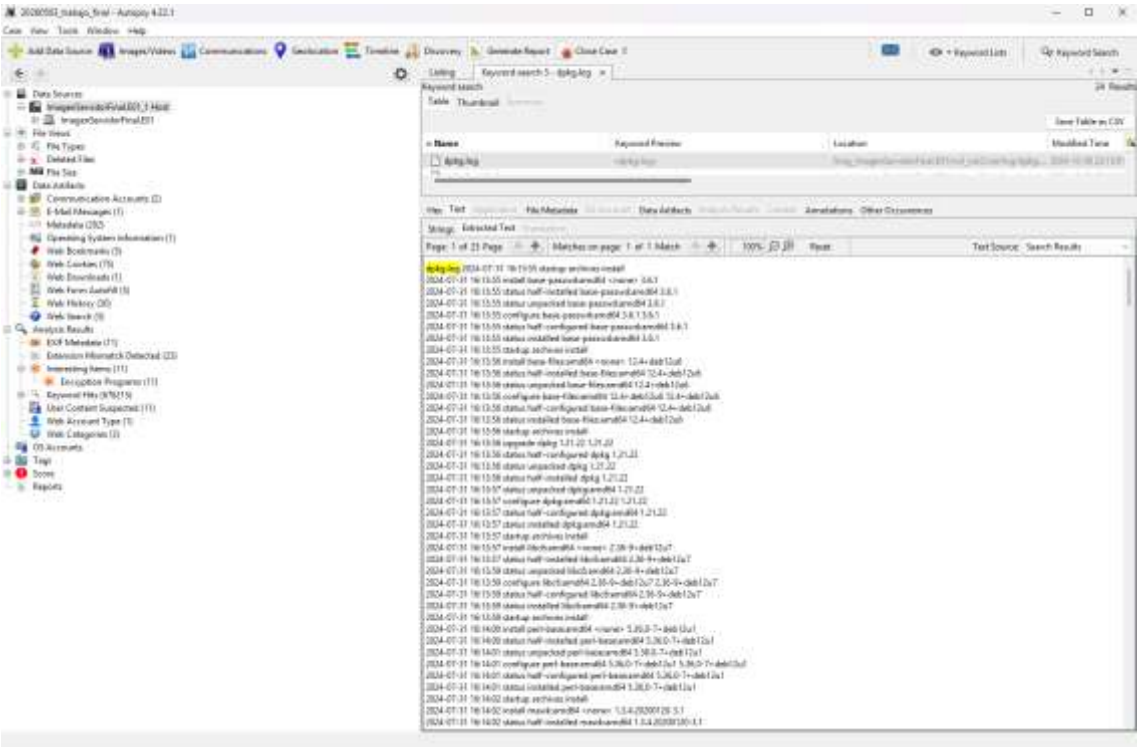
Visualización del Archivo VSFTPD.CONF



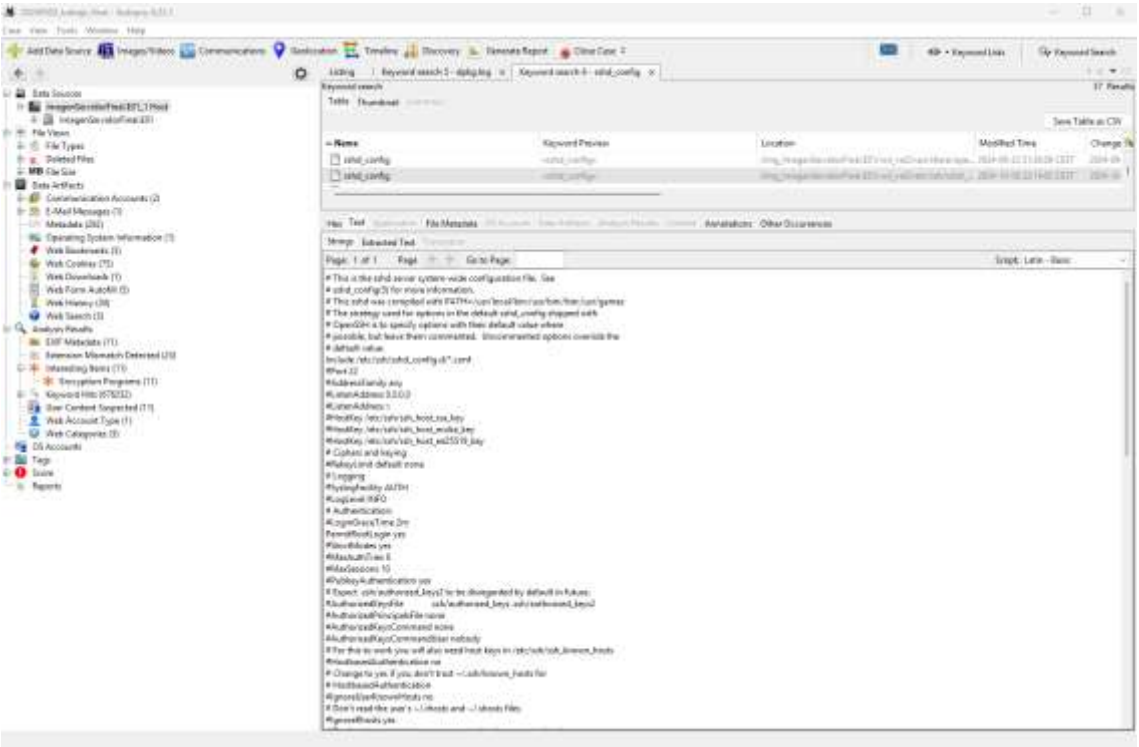
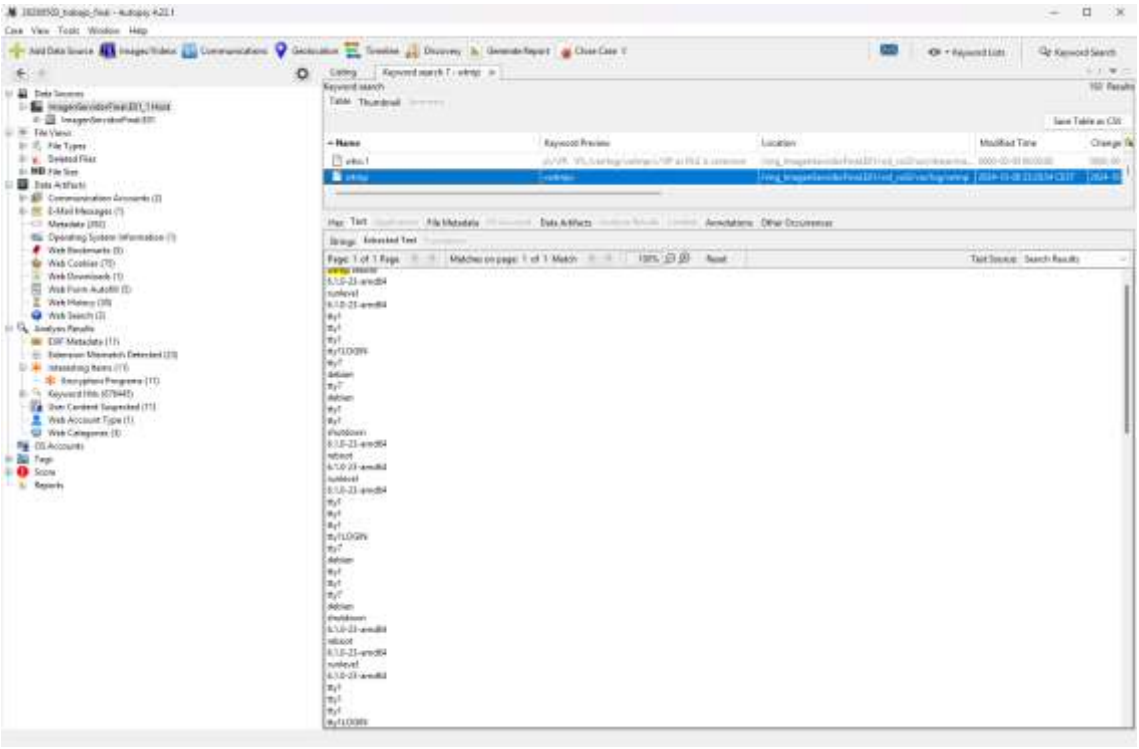
Visualización del Archivo WP-CONFIG.PHP



Visualización del Archivo DPKG.LOG



Visualización del Archivo SSHD_CONFIG



Visualización del Archivo WTMP